

NIS-2-Risikomanagementmaßnahmen

Wichtige und besonders wichtige Einrichtungen müssen gemäß § 30 BSIG-E umfassende technische und organisatorische Risikomanagementmaßnahmen umsetzen.

- Risikomanagementmaßnahmen sollen dazu dienen, Störungen der Verfügbarkeit, Integrität und Vertraulichkeit von informationstechnischen Systemen, Komponenten und Prozessen, die für die Erbringung der Dienste genutzt werden, zu vermeiden und Auswirkungen von Sicherheitsvorfällen möglichst gering zu halten.
- Risikomanagementmaßnahmen müssen geeignet, verhältnismäßig und wirksam sein. Es ist daher unerlässlich, dass vor der Umsetzung von Risikomanagementmaßnahmen eine Risikoanalyse durchgeführt und die Maßnahmen kontinuierlich evaluiert und angepasst werden.
- Einrichtungen sind verpflichtet, die getroffenen Maßnahmen angemessen zu dokumentieren. Die Dokumentation umfasst mindestens die identifizierten Risiken, die Entscheidungen, entsprechende Maßnahmen zu ergreifen sowie Informationen zu deren Umsetzung.
- Es wird empfohlen, ein Informationssicherheits-Managementsystem (ISMS) zu implementieren.



© AdobeStock – olly_236480967

Mehr Infos: www.bsi.bund.de/dok/nis-2-risikomanagement

Version 1.0 – 21.11.2025